

Diagnostic et préconisations de sécurité - MSAP

1. Configurations à risque (Documents 1 et 2)

L'examen des configurations actuelles révèle des failles de sécurité majeures :

- **Comptes locaux résiduels** : Bien que les utilisateurs s'identifient via l'Active Directory, des comptes locaux tels que "Administrateur", "DefaultAccount" et "Invité" sont présents sur les machines. Le compte "Invité" actif constitue une vulnérabilité critique.
- **Élévation de privilèges par héritage** : Le groupe "partenaires" est membre du groupe "Administrateurs". Par conséquent, tous les membres des groupes partenaires (clic, enedis, msa, tresor) héritent de droits d'administration totale sur le domaine.
- **Absence de cloisonnement** : Tous les partenaires sont regroupés dans une structure commune ("partenaires"), ce qui favorise les accès transversaux non autorisés.

2. Synthèse des bonnes pratiques (Documents 3 et 4)

Pour corriger ces failles, les mesures suivantes doivent être appliquées :

- **Principe du moindre privilège** : Les utilisateurs ne doivent disposer que des accès nécessaires à leurs missions.
- **Restriction des accès partagés** : Les autorisations de partage pour le groupe "Tout le monde" (Everyone) doivent être supprimées. Actuellement, ce groupe dispose de permissions sur le dossier "PartageTelecentre".
- **Gestion granulaire NTFS** : Il est impératif de définir des droits spécifiques pour chaque dossier partenaire (ex : seul le groupe ENEDIS accède au dossier **enedis**) au lieu d'accorder des droits globaux sur la racine du partage.

3. Risques induits par les privilèges excessifs (Document 4)

L'attribution de droits trop larges (Modification/Contrôle total) expose la MSAP à :

- **Compromission de l'intégrité** : Un utilisateur peut modifier ou supprimer des données critiques appartenant à d'autres partenaires.
- **Risque d'attaque latérale** : Si un compte du groupe "partenaires" est compromis, l'attaquant dispose immédiatement de privilèges administrateur pour s'étendre sur le réseau.

4. Préconisations pour la segmentation (Document 5)

La sécurisation réseau doit s'appuyer sur une isolation logique et filtrée :

- **Segmentation par VLAN** : Maintenir l'isolation des partenaires dans des VLAN distincts (VLAN10, 20, 30, 40).
- **Filtrage par Access Control Lists (ACL)** : Configurer le routeur principal pour interdire les flux entre les VLANs des partenaires tout en autorisant l'accès au VLAN 100 du serveur de fichiers.
- **Syntaxe de filtrage (Exemple Cisco)** : Pour bloquer un flux, utiliser la commande :

deny 192.168.X.0 0.0.0.255 192.168.Y.0 0.0.0.255

où *X* et *Y* sont les sous-réseaux des différents partenaires.